

Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

The database is valuable for the organization because the employees of the company regularly query, or request, data from the server to find potential customers. The database is important because it stores customer information, necessary for an e-commerce company; its revenue is based on its ability to lure customers, a task allowed by querying data in the remote server. The company would suffer a decrease in its utility and corporate image if the database is compromised; the public will know the company as the one who doesn't protect the data of customers or potential customers.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Hacker	Obtain sensitive information via exfiltration	3	3	9
Malicious software	Perform reconnaissance and surveillance of organization	3	2	6
Hacktivist	Conduct Denial of Service (DoS) attacks.	3	2	6

Approach

The threats were selected considering the nature of the database and the information it stores, which is misconfigured as public access. The likelihood of a threat occurrence and the impact of these potential events were weighed against the risks to day-to-day operational needs. These threats involve significant business risks which can damage the image, customer strategy and compliance of the organization .

Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls, and multi-factor authentication to limit user privileges.

Also, it is strongly recommended the implementation of a defense in depth strategy. This includes measures like implementing encryption of data in motion using TLS instead of SSL; usage of firewalls, Intrusion Prevention Systems and IP allow-listing to corporate offices to prevent random users from the internet from connecting to the database; and usage of antivirus for the remote server.